



VotePriv

Private voting on Midnight

Prove you are eligible, seal your choice, let anyone audit the tally — and nobody, including the organiser, learns who voted for what.

Midnight preview · Compact

Lace 4.0.1

Apache-2.0

github.com/mdlog/votepriv

On-chain voting is **public** by default

- Address and choice sit side by side on the ledger — **forever**.
- "Private" designs usually just **move the trust**: a tally server that sees plaintext, a relay that learns who you are, a proof service run by the organiser.
- Governance needs the opposite: **eligibility and participation provable, identity and choice not**.

What has to be true

Only eligible people vote · one person, one vote · the tally is verifiable by anyone · no party — not even the organiser — can map a voter to a choice.

Eligibility without identity, choice without exposure

- **Secret credential, public leaf.** Only the hash of a voter's credential is registered, in a Merkle tree on-chain.
- **Casting is a ZK proof** of tree membership — the chain never learns which leaf.
- **One credential, one vote:** a per-ballot nullifier is published on cast; a second cast is rejected.
- **Two-phase tally.** The choice is a sealed commitment until the vote deadline; it is opened with a *second* nullifier that cannot be linked to the cast.
- **The organiser never holds a secret** — credentials are generated in the voter's browser.
- **The proof server runs on the voter's machine**, so the witness (credential + choice) never leaves it.

Four circuits, one privacy invariant

registerVoters

Admin only. Inserts up to 8 leaves into a

`HistoricMerkleTree<10>`.
Open until the vote deadline.



castVote

Proves `cred_leaf(cred)` is in the tree, publishes `vote_nullifier(nonce, cred)`, inserts `vote_commitment(option, salt)`. Stores the opening privately.



tallyVote

After the deadline: proves the commitment is in the tree, publishes `tally_nullifier(salt)`, discloses only the option, increments the tally.



What the ledger holds: sealed metadata, leaves, nullifiers, commitments, tallies. **What it never holds:** a credential, a salt, or a voter-to-choice mapping. All hashes are `export pure` circuits, so the client never re-implements hashing.

Public state on-chain, private state at home

Public — decoded by anyone from the indexer

Ballot metadata, eligibility tree, nullifier set, commitment tree, tallies, phase. The app reads them with raw GraphQL and the generated `ledger()` — an indexer outage is never rendered as "no ballots".

Private — the witness side

Credential, the `(option, salt)` opening written by `store_opening`, and the Merkle paths the client builds. Kept per ballot in IndexedDB (browser) or LevelDB (CLI). Only a proof crosses the boundary.

Write path: `findDeployedContract` verifies the on-chain verifier keys → witness → `proveTx` on the **local** proof server → Lace balances and submits. The 10 MB write-path WASM is a lazily loaded chunk, guarded by a test.

A proof server the voter controls

- Whoever runs the proof server sees the witness. So VotePriv ships a **one-file Docker package**: app + proof server in one network namespace, port 6300 never published.
- Image on GHCR with **provenance + SBOM**, compose pinned by **digest**; the release gate refuses to publish unless the packaged proof-server path verifies as local.
- Offline parameter bundle for machines whose containers cannot reach the internet.

The UI only claims what it can verify

The privacy indicator says "**Always on**" only after the app has confirmed, at runtime, that the proof server it talks to is local. Otherwise it names the machine that will see your witness.

Register from any laptop — no wallet, no organiser online

1 · Browser

Generates a 32-byte credential, keeps it in IndexedDB, computes the public leaf.



2 · Inbox address from the chain

The ballot's sealed policy names the organiser's registration inbox. Only the leaf is sent.



3 · Organiser inbox

Registers it at once — one `registerVoters` transaction per batch of whatever is queued. Holds only hashes.



4 · Verified, not trusted

The app reports "Registered on-chain" only after finding the leaf in the eligibility tree it decodes from the indexer.

The contract was changed for this: registration is closed by the vote deadline, not by the first vote — safe because choices stay sealed until then and `registeredCount` is public.

EVIDENCE, NOT CLAIMS

Deployed, tested, verifiable

1,020

tests across contract simulator, CLI, shared and app — guards mutation-checked before commit.

0

payer identity fields in real Midnight transactions — proven by deserializing them, which killed a relayer we were about to build.

3/3

votes cast, opened and finalized on preview by the CLI end-to-end run; browser votes via Lace landed on live ballots.

Registry v2 c42681741bfff50e346b9e80493b622c57883f748cc0a3af60f71545e6f8ff35a

Live ballot cf5e2e1e71a31cf5a3e06479844ecff88d75cb3f7190565209098f1b55e02e13

Finalized ballot c270b8d0fe4176a0a623866d6f42597a5625f3730b341fc665ef7af5df563d8d

Three ways for judges to test

- **Read only:** `votepriv.mdloglabs.org` — ballots and results decoded live from the preview indexer.
- **Register and vote:** `docker compose -f docker-compose.voter.yml up` → `localhost:5300` → *Register to vote* (no wallet) → *Vote privately* with Lace on preview.
- **Contracts:** `pnpm --filter contract compact` and `pnpm --filter contract test`.

Honest limits

Anonymity is the size of the voter set. Off-chain metadata (timing, IP) is out of scope. The credential backup file is the vote in the clear. Testnet only; not audited.

Wave 2 → Wave 3

Wave 2 — usable by a real community

Invitation-based eligibility without the organiser online · larger anonymity sets up to 1,024 leaves · tally-phase UX and per-option results · multi-ballot inbox and organiser dashboard · contract hardening and external review of the Merkle/nullifier design.

Wave 3 — something an organisation would run

Ballot creation from the app via Lace · attribute-bound eligibility proven in-circuit · a standalone auditor that recomputes tally, nullifiers and root from the chain alone · hosted inbox + self-hosted proof-server guidance · a pilot with a real community, then a security review.

VotePriv — private for the voter, verifiable for everyone. github.com/mdlog/votepriv ·